

## **Security in the Cloud TASK – 4**

- 1. Download a sample IAM policy JSON (for example, from AWS documentation), identify all users and their permissions, and list any permissions that are broader than necessary for typical user actions.**

**Ans :**

- {
  - "Version": "2012-10-17",
  - "Statement": [  - {
    - "Effect": "Allow",
    - "Action": "s3:\*",
    - "Resource": "\*"
  - },
  - {
    - "Effect": "Allow",
    - "Action": [    - "ec2:DescribeInstances",
    - "ec2:StartInstances",
    - "ec2:StopInstances"
    - ],
    - "Resource": "\*"
  - }
  - ]
  - }
- User identified: One IAM user (or any IAM identity to which the policy is attached).

- Permissions granted: Full S3 access and the ability to view, start, and stop EC2 instances.
- Overly broad permissions:
  - s3:\*
  - Resource: "\*" for S3
  - EC2 start/stop permissions on all instances (Resource: "\*")

**2. Edit the given IAM policy to implement least privilege access for a food delivery app scenario (e.g., only allow delivery agents to update order status, not delete orders), and save your revised policy as `optimized_policy.json`.**

**Ans :**

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ViewAndUpdateOrderStatus",
      "Effect": "Allow",
      "Action": [
        "dynamodb:GetItem",
        "dynamodb:Query",
        "dynamodb:UpdateItem"
      ],
      "Resource": "arn:aws:dynamodb:*:*:table/Orders"
    }
  ]
}
```

}

3. Review an IAM policy that grants full S3 access to a group called 'AppUsers' and modify it so users can only read from a specific bucket named 'user-uploads', not write or delete files.<br><br><em><strong>Hint:</strong> Use the 'Action' and 'Resource' fields to restrict permissions.</em>

Ans :

- {
  - "Version": "2012-10-17",
  - "Statement": [  - {
    - "Sid": "ListUserUploadsBucket",
    - "Effect": "Allow",
    - "Action": "s3:ListBucket",
    - "Resource": "arn:aws:s3:::user-uploads"
  - },
  - {
    - "Sid": "ReadUserUploads",
    - "Effect": "Allow",
    - "Action": "s3:GetObject",
    - "Resource": "arn:aws:s3:::user-uploads/\*"
  - }
  - ]
  - }
- Attach the revised policy to the AppUsers group (or update the existing policy if it is already attached).
  - Test the policy to verify that users in the AppUsers group can:
  - View the list of files in the user-uploads bucket (s3:ListBucket).

- Read/download files from the user-uploads bucket (s3:GetObject).
- Cannot upload files (s3:PutObject).
- Cannot delete files (s3:DeleteObject).
- Cannot modify bucket settings or permissions.

**4. Write a checklist of 5 steps you would follow to regularly review IAM policies for a movie ticket booking app (like BookMyShow), including how you would identify unused permissions and revoke them.**

**Ans :**

- Review IAM Users, Groups, and Roles
  - Check all IAM users, groups, and roles used by the application (e.g., customer support, booking service, payment service, administrators).
  - Verify that each identity has only the permissions required for its job.
- Identify Unused Permissions
  - Use IAM Access Analyzer and AWS CloudTrail to review which permissions have actually been used.
  - Identify permissions that have not been used for a significant period and determine whether they are still required.
- Apply the Principle of Least Privilege
  - Remove unnecessary actions such as wildcard permissions (\*) or full access policies.

- Restrict access to only the required AWS services, resources, and actions (for example, allow customer support to read booking details but not delete bookings).
- Revoke Excess Permissions
  - Edit or replace IAM policies to remove unused or excessive permissions.
  - Detach obsolete managed policies and delete unused inline policies after confirming they are no longer needed.
- Test and Monitor Changes
  - Use the AWS IAM Policy Simulator to verify that users can perform only their required tasks.

**5. Use ChatGPT or another AI tool to analyze a provided IAM policy snippet and suggest at least two improvements to enhance security following best practices.<br><br><em><strong>Hint:</strong> Paste the policy into the AI tool and ask for recommendations based on least privilege and regular review.</em>**

**Ans :**

- Restrict Actions to Required Permissions
- Replace "Action": "\*" with only the specific actions needed for the user's role.
- Example: If a user only needs to view S3 files, allow only
- "Action": [
- "s3:GetObject",
- "s3:ListBucket"
- ]
- Restrict Resource Access

- Replace "Resource": "\*" with specific resource ARNs.
- Example
- "Resource": "arn:aws:s3:::user-uploads/\*"